CYBERCRIME AWARENESS — TASK 5

# CASE STUDY

PhishingAttack The2020Twitter

Bitcoin Scam

CASE STUDY BY Akshat Mujmer
25MIP10029

| Task 5 | Cybercrime: Phishing | Real Published Incident | ~1,200 Words |
|---|---|---|---|

***This case study examines one of the most high-profile social engineering and phishing attacks in the history of social media. On July 15, 2020, attackers successfully compromised verified Twitter accounts belonging to Barack Obama, Elon Musk, Bill Gates, Apple, Uber, and dozens of other prominent figures. The incident exposed critical vulnerabilities in internal employee verification processes and resulted in approximately $120,000 USD in Bitcoin losses, three arrests, and sweeping changes to Twitter's internal security architecture. The case serves as a defining illustration of how sophisticated phishing attacks exploit human psychology rather than technical vulnerabilities.***

| DATE OF INCIDENT | ATTACK TYPE | VICTIMS | FINANCIAL LOSS | ARRESTS MADE |
|---|---|---|---|---|
| July 15, 2020 | Spear Phishing + Social Engineering | 130+ Verified Twitter Accounts | ~$120,000 USD in Bitcoin | 3 Individuals (ages 17–22) |

## 01 What Is Phishing?

Phishing is a form of cybercrime in which an attacker impersonates a trusted, legitimate entity — such as a financial institution, a technology company, a government body, or a well-known individual — with the intent of deceiving victims into revealing sensitive personal information, transferring money, or clicking malicious links that install malware. The term is derived from the word 'fishing,' reflecting how criminals bait their victims with convincing lures, hoping that at least a portion will take the hook.

Unlike traditional hacking — which exploits weaknesses in software, operating systems, or network infrastructure — phishing is fundamentally a psychological attack. It leverages deeply human cognitive

tendencies: trust in authority, fear of consequences, urgency under pressure, excitement at opportunity, and the natural desire to be helpful. These psychological levers make phishing effective against even technically sophisticated individuals.

Phishing attacks are delivered through multiple channels. Email phishing (sometimes called 'email spoofing') is the most prevalent form. SMS-based phishing, known as 'smishing,' targets mobile users with deceptive text messages. Voice phishing, or 'vishing,' involves phone calls from attackers impersonating customer service representatives or IT personnel. Spear phishing is a particularly dangerous variant in which attackers tailor their approach to a specific, pre-researched individual or organisation rather than casting a wide net.

According to the FBI's Internet Crime Complaint Center (IC3), phishing was the single most reported cybercrime in the United States in 2022, with over 300,000 reported incidents. The global economic impact of phishing across all sectors runs into the billions of dollars annually. Despite advances in spam filtering, multi-factor authentication, and cybersecurity training, phishing remains the number-one initial attack vector for data breaches worldwide.

| TYPE | CHANNEL | HOW IT WORKS |
|---|---|---|
| Email Phishing | Email | Mass-sent fraudulent emails mimicking trusted brands |
| Spear Phishing | Email/Phone | Targeted attack on a specific individual or organisation |
| Smishing | SMS/Text | Deceptive text messages with malicious links |
| Vishing | Phone Call | Voice calls impersonating banks, IT support, or government |
| Clone Phishing | Email | Duplicated legitimate email with malicious links swapped in |
| Whaling | Email/Phone | High-value spear phishing targeting executives (CEOs, CFOs) |

Table 1 — Common Phishing Attack Variants

## 02 The Incident: 2020 Twitter Bitcoin Scam

### Background

On the afternoon of Wednesday, July 15, 2020, Twitter users around the world began noticing something deeply unusual: verified accounts belonging to some of the most recognised names on the planet were all posting suspiciously similar messages. The accounts of former U.S. President **Barack Obama**, President-elect **Joe Biden**, billionaire entrepreneur **Elon Musk**, philanthropist **Bill Gates**, rapper **Kanye West**, Amazon founder **Jeff Bezos**, and major corporations including **Apple** and **Uber** were all promoting the same Bitcoin giveaway scam.

The posts all followed an identical template, telling followers that during the COVID-19 pandemic, the named individual or company was 'giving back' to the community, and that anyone who sent Bitcoin to a specified wallet address would receive double the amount back within 30 minutes. In total, more than **130 high-profile accounts** were affected, approximately 45 of which were used to actively post the fraudulent messages.

WARNING — KEY INSIGHT: This attack was not the result of a software vulnerability or a database breach. The attackers did not break through Twitter's firewalls or decrypt any encryption. Instead, they achieved their access entirely through human manipulation — deceiving Twitter employees into handing over the keys themselves. This illustrates why phishing remains the dominant entry point for even the world's most technically sophisticated organisations.

## 03 How the Attack Happened: Step-by-Step

1

### Step 1 — Reconnaissance and Target Research

The attackers — later identified as a small group of young cybercriminals — began by conducting detailed reconnaissance on Twitter's internal structure. They studied publicly available information about Twitter's organisational layout, job titles, and internal support systems. They identified that certain Twitter employees had elevated administrative privileges, including access to powerful internal tools capable of overriding account security settings. Online forums used by hackers reportedly played a role in initial coordination and intelligence gathering.

2

### Step 2 — Spear Phishing Twitter Employees by Phone (Vishing)

Rather than sending mass phishing emails, the attackers employed a far more targeted approach: they placed direct phone calls to Twitter employees, impersonating members of Twitter's own internal IT department. Speaking with authority and using specific internal terminology, they told employees that there was an urgent technical issue — such as a VPN problem during remote work — that required immediate verification of the employee's internal account credentials. This technique, known as vishing (voice phishing), exploits the natural human tendency to comply with authority figures, especially in workplace contexts involving perceived urgency.

3

### Step 3 — Credential Harvesting via Fake Internal Portal

The attackers directed employees to a fraudulent website that convincingly mimicked Twitter's internal employee credential portal. Employees who trusted the caller entered their username and password into the fake site, unknowingly handing over their login credentials to the attackers in real time. The fake portal was designed to log credentials as they were entered and forward them immediately to the attackers, who would then attempt to use them before the employee became suspicious.

4

### Step 4 — Bypassing Multi-Factor Authentication in Real Time

Twitter — likemost majororganisations— required multi-factor authentication (MFA) for employee account access. To overcome this, the attackers used a real-time MFA relay attack. When the employee's credentials were captured, the attackers immediately attempted to log in to the real Twitter systems. When the MFA prompt appeared on the employee's device, the fake portal simultaneously presented the employee with a field asking them to enter the code 'for verification.' The employee entered their MFA code into the fake site, the attackers captured it within seconds, and used it to complete authentication on the real Twitter platform before it expired.

5

### Step 5 — Accessing Twitter's Internal Admin Tools ('God Mode')

With validcredentialsandauthenticatedsessions, theattackers gained access to Twitter's internal administrative back-end — an extremely powerful set of tools that Twitter engineers and support staff use to manage accounts. Dubbed 'Twitter God Mode' in media reports, this system allowed operators to view private account information, change registered email addresses, disable two-factor authentication, and effectively take full control of any account on the platform, including those with the most stringent security settings.

6

### Step 6 — Account Hijacking — Locking Out Legitimate Owners

The attackerssystematically selected high-profile verified accountsbased on follower count and recognisability. For each target account, they changed the registered email address to one they controlled, disabled the account's existing two-factor authentication, and effectively locked out the real account owner. Once the email address was changed, Twitter's own security systems — password reset emails, account recovery notifications — were redirected to the attacker's inbox rather than the legitimate owner's.

7

### Step 7 — Broadcasting the Phishing Scam to Hundreds of Millions

From thecompromised accounts,t heattackersposted near-identical messages. Each post was carefully worded to appear genuine, leveraging the immense credibility of the account holder. Because the tweets appeared on verified, blue-checkmarked accounts, millions of followers had no immediate reason to doubt their authenticity. The Bitcoin wallet addresses included in the posts received funds almost immediately. Within the first hour alone, hundreds of transactions were recorded.

8

### Step 8 — Collecting the Proceeds — $120,000 in Bitcoin

Bitcoin'sfundamentalcharacteristicsmadethis the idealvehicleforthefraud: transactions are pseudonymous (linked to wallet addresses, not real identities), irreversible (once confirmed, they cannot be recalled), and near-instant. By the time Twitter identified the breach and began taking down the fraudulent posts — and eventually disabling the ability of all verified accounts to post — the attackers had already collected approximately $120,000 USD worth of Bitcoin from over 400 separate transactions from victims around the world.

9

### Step 9 — Detection, Platform Response, and Investigation

Twitter's security team identified thebr each withinhours.Thecompany temporarily disabled the ability for all verified accounts globally to post tweets while the incident was contained — an unprecedented measure that affected politicians, journalists, celebrities, and news organisations worldwide. Twitter issued a public statement acknowledging 'a coordinated social engineering attack.' The FBI, IRS Criminal Investigation Division, and the U.S. Secret Service launched a joint investigation.

10

### Step 10 — Arrests and Legal Consequences

Withinw eeks of the attack, investigators traced the Bitcoin wallet transactions and cross-referenced digital forensic evidence. Three individuals were identified and arrested: Graham Ivan Clark (17 years old, Tampa, Florida), Nima Fazeli (22, Orlando, Florida), and Mason Sheppard (19, Bognor Regis, United Kingdom). Clark, widely considered the ringleader, pleaded guilty in March 2021 to fraud and cybercrime charges under a plea agreement and was sentenced to three years in a juvenile detention facility — the maximum available under Florida juvenile sentencing law. Fazeli and Sheppard faced federal criminal charges with potential sentences of up to 20 years in prison.

## 04 Who Is Usually Targeted by Phishing?

Phishing attacks target a remarkably broad range of individuals and organisations. While no group is immune, certain categories are disproportionately affected due to either the value of access they represent or their relative vulnerability to social manipulation.

| TARGET GROUP | WHY THEY ARE TARGETED | EXAMPLE ATTACK |
|---|---|---|
| General Internet Users | Large numbers; lower cybersecurity aware | Fnaekses; beaanskil ys eaclaurrmitye da lbeyrt uermgeanilst fraekqeu ev |
| Corporate Employees | Access to company financial systems, clien | ITt dimatpae, rasnodn aintitoenrn vaisl hnientgw ocarklls — as in the Tw |
| Elderly Individuals | Less familiarity with digital fraud tactics; mo | IRreS t riumsptienrgs onf aotfifoicni acla-sllosu tnhdreinagte cnoinmgm a |
| High-Net-Worth Individuals | Larger potential financial returns; often hav | We hsatalifnf gw ehmo acailsn tbaerg metaingip CulFaOtesd for fraudule |
| Healthcare & Government Wo | Arckceerss to sensitive, classified, or personall | Cy OidVeInDti-f1ia9b pleo rdtatl aphishing targeting NHS or governr |
| Cryptocurrency Holders | Irreversible blockchain transactions; pseud | Foankyem witya lliemt itvse reificcoavtieorny emails; giveaway scams (a |
| Social Media Influencers | Large follower bases amplify reach; brand | Fdaekael imbrpaenrds opnaarttnioenrsihs ipcr emdibaliels with malicious |

Table 2 — Common Phishing Target Groups, Motivations, and Attack Patterns

In the 2020 Twitter attack, the initial targets were a small number of Twitter employees with privileged access — these were the 'entry point' victims. The secondary and far larger group of victims were ordinary social media users worldwide who, trusting the verified accounts of Barack Obama, Elon Musk, and others, transferred real cryptocurrency in the belief they were participating in a charitable giveaway.

# 05 Consequences of the Attack

## 5.1 For Individual Victims

Forthehundreds ofordinary userswho sent Bitcoin to the fraudulent wallet addresses, the consequences were immediate and largely irreversible. Bitcoin transactions, once confirmed on the blockchain, cannot be reversed or recalled — unlike credit card chargebacks or bank wire recalls. The average individual transaction value in the Twitter scam was approximately $300, though some victims transferred far more. Beyond financial loss, victims reported feelings of embarrassment, anger, and a lasting erosion of trust in online platforms and the credibility of verified accounts.

- Direct, unrecoverable financial losses due to the irreversibility of Bitcoin transactions
- Emotional distress including shame, anxiety, and anger — particularly for victims who transferred large sums
- Lasting loss of trust in social media platforms and verified accounts as reliable sources
- In cases where personal accounts were compromised: risk of identity theft, reputation damage, and exposure of private messages

## 5.2 For Twitter as an Organisation

TheconsequencesforTwitterweresevere,multifaceted, and long-lasting. The breach exposed fundamental weaknesses in Twitter's internal access control, employee verification protocols, and the security architecture of its administrative tools. The reputational damage was immediate and global, receiving front-page coverage in every major news outlet.

- Severe and immediate reputational damage — global headlines raised fundamental questions about Twitter's ability to protect its platform
- Twitter's share price dropped approximately 4% in after-hours trading on the day of the breach
- The company was forced to temporarily disable posting capabilities for all verified accounts globally — an unprecedented operational disruption affecting millions
- Regulatory scrutiny intensified, with U.S. senators calling for a formal investigation into Twitter's security practices
- Twitter invested heavily in post-breach security improvements, including overhauling its internal admin tool access controls and employee security training
- Public trust in the 'verified' blue checkmark system — a core pillar of Twitter's identity and credibility — was severely undermined

## 5.3 For Society and the Digital Ecosystem

Beyondthe direct parties,the2020Twitter hackhadbroader societal implications. It raised urgent questions about the role of social media platforms during elections, public health crises, and other moments of heightened information need — and what would happen if a state-level actor, rather than teenagers seeking financial gain, had access to the same administrative tools.

- Erosion of public confidence in social media as a reliable channel for communications from public figures, governments, and health authorities

- Demonstrated that a sufficiently motivated attacker could potentially use compromised accounts to spread dangerous misinformation during crises such as elections or pandemics
- Prompted industry-wide re-evaluation of administrative access protocols, zero-trust security architectures, and employee social engineering training
- Highlighted the systemic risks posed by centralised control systems — the fact that a handful of admin accounts could control the entire platform

### 5.4 Legal Consequences for Perpetrators

| PERPETRATOR | AGE | CHARGES | OUTCOME |
|---|---|---|---|
| Graham Ivan Clark (Ringleader) | 17 (Florida) | 30 felony counts including fraud, identity theft, and computer crimes | 3 years juvenile detention (maximum under FL law) Plus 3 years probation |
| Nima Fazeli (Co-conspirator) | 22 (Florida) | Federal charges: wire fraud, money laundering, identity theft | Federal prosecution Up to 20 years possible |
| Mason Sheppard (Co-conspirator) | 19 (UK) | Federal charges: wire fraud, conspiracy to commit fraud | Federal prosecution Extradition proceedings |

Table 3 — Legal Outcomes for Perpetrators of the 2020 Twitter Hack

## 06 Prevention and Protective Measures

The 2020 Twitter attack underscores a principle that security professionals have long emphasised: no amount of technical security can fully compensate for an absence of human security culture. Effective defence against phishing requires a layered approach combining technology, process, and awareness.

### For Individuals:

- **Never share credentials verbally or in writing.** No legitimate organisation — not your bank, your employer, not Twitter's IT department — will ever call you and ask for your password or MFA code.
- **Verify identities independently.** If you receive an urgent call from someone claiming to be IT support, hang up and call the organisation's official, publicly listed number.
- **Use hardware security keys (FIDO2/WebAuthn)** for multi-factor authentication where possible. Unlike SMS codes or app-generated codes, hardware keys cannot be intercepted by a real-time relay attack.
- **Be sceptical of urgency.** Phishing attacks almost always create a false sense of urgency. If something feels urgent and pressured, that is itself a warning sign.
- **Check URLs carefully** before entering credentials — a domain like 'twitter-support-portal.com' is not the same as 'twitter.com'.
- **Enable login notifications** so you are alerted immediately if your account is accessed from an unrecognised device or location.
- **Report suspicious messages** to the platform, your organisation's IT security team, and relevant national cybercrime reporting agencies.

### For Organisations:

- **Implement a Zero-Trust security architecture:** assume no user or device is inherently trustworthy; verify every access request, even from internal networks.
- **Apply the Principle of Least Privilege:** employees should have access only to the systems and data strictly required for their role — no more.
- **Conduct regular social engineering simulations** and phishing resistance training across all staff, with particular focus on employees with elevated system access.
- **Require hardware security keys** for all employees accessing administrative or privileged systems — this would have likely defeated the real-time MFA relay used in the Twitter attack.
- **Implement strict internal verification protocols** for any request involving credential changes or access to sensitive tools — verbal requests alone should never be sufficient.
- **Segment administrative tools** so that a single compromised employee account cannot yield platform-wide control.
- **Maintain detailed audit logs** of all administrative actions so that breaches can be rapidly detected, traced, and contained.

- **Implement strict internal verification protocols** for any request involving credential changes or access to sensitive tools — verbal requests alone should never be sufficient.
- **Segment administrative tools** so that a single compromised employee account cannot yield platform-wide control.
- **Maintain detailed audit logs** of all administrative actions so that breaches can be rapidly detected, traced, and contained.

## 07 Summary and Key Takeaways

The 2020 Twitter Bitcoin scam stands as one of the most significant and instructive cybercrime incidents of the social media era. In a matter of hours, a small group of young attackers — without deploying a single line of malicious code — compromised one of the world's most powerful communications platforms and used it to defraud hundreds of people globally. Their weapon was not a zero-day exploit or a sophisticated botnet. It was a phone call.

This case encapsulates the defining truth of modern cybercrime: the human element is almost always the most vulnerable link in any security chain. Twitter had invested heavily in technical security infrastructure. It had multi-factor authentication. It had encrypted communications. It had firewalls and intrusion detection systems. None of these defences mattered when an employee was convinced — in a matter of minutes, over the telephone — to hand over their credentials to a stranger.

> ***"Technology alone cannot protect against human manipulation. Awareness, scepticism, and a strong organisational security culture remain the most powerful defences against phishing attacks — because when people are the target, people must also be the solution."***

For students of cybercrime and cybersecurity, the key takeaways from this case study are:

- Phishing attacks are fundamentally psychological, not technical — understanding human behaviour is as important as understanding code
- Spear phishing and vishing are among the most effective attack vectors precisely because they are personalised and delivered in real time

• No organisation, regardless of size, technical sophistication, or budget, is immune to phishing if its employees are not adequately trained and if its internal processes lack robust verification requirements

• Cryptocurrency's pseudonymity and irreversibility make it the preferred medium for phishing-related financial fraud

• The consequences of phishing extend far beyond the immediate financial loss — reputational damage, regulatory scrutiny, and lasting erosion of public trust can be even more damaging in the long term

## 08 Sources and References

All sources listed below are publicly available and were consulted in the preparation of this case study. Where incident-specific details are cited (arrest dates, financial figures, account counts), they are drawn from official government statements, platform disclosures, or established investigative journalism.

**[1] BBC News (2020)**

Twitter hack: Three charged over massive celebrity account takeover. BBC News. Published: July 31, 2020. URL: https://www.bbc.com/news/technology-53607374 This article provides a detailed account of the arrests and charges filed against the three perpetrators, including their ages, locations, and the specific charges brought by U.S. federal authorities and Florida state prosecutors.

**[2] United States Department of Justice (2020)**

ThreeI ndividuals Charged forAllegedRolesinTwitter Hack. U.S. DOJ — Northern District of California. Published: July 31, 2020. URL: https://www.justice.gov/usao-ndca/pr/three-individuals-charged-alleged-roles-twitter-hack Official DOJ press release detailing the criminal complaints, charges (wire fraud, money laundering, identity theft), and the coordinated investigation involving the FBI, IRS-CI, and Secret Service.

**[3] Twitter Inc. (2020)**

Anu pdateon oursecurity incident. Twitter Blog (Official Company Statement). Published: July 30, 2020. URL: https://blog.twitter.com/en_us/topics/company/2020/an-update-on-our-security-incident Twitter's official post-incident statement, confirming the number of accounts affected, the nature of the social engineering attack, and the temporary measures taken including the suspension of verified account posting capabilities.

**[4] FBI Internet Crime Complaint Center — IC3 (2022)**

InternetC rimeReport 2022. FederalBureauofInvestigation. Published: 2023. URL: https://www.ic3.gov/Media/PDF/AnnualReport/2022_IC3Report.pdf The FBI's annual cybercrime statistics report, confirming phishing as the most reported cybercrime in the United States in 2022, with over 300,000 complaints filed and losses exceeding $52 million in that category alone.

**[5] Krebs on Security (2020)**

Who's Behind Wednesday's Twitter Hijacking? Brian Krebs — Independent Cybersecurity Journalist. Published: July 16, 2020. URL: https://krebsonsecurity.com/2020/07/whos-behind-wednesdays-twitter-hijacking/ This detailed investigative report by renowned cybersecurity journalist Brian Krebs provides early analysis of the attack's mechanics, including the role of underground hacker communities and the specific techniques used to obtain internal Twitter access.

**[6] New York Times — Technology (2020)**

How TwitterWasHacked—and WhoHelped. The New York Times. Published: July 17, 2020. URL: https://www.nytimes.com/2020/07/17/technology/twitter-hackers-interview.html An investigative report including interviews with individuals who claimed direct knowledge of the attack, providing insight into the social engineering techniques, the role of the OGUsers forum, and the internal Twitter tool referred to as 'Twitter God Mode.'

**[7] CISA — Cybersecurity and Infrastructure Security Agency (2021)**

PhishingG uidance:StoppingtheAttack CycleatPhaseOne. U.S.Department of Homeland Security — CISA. Published: 2021. URL: https://www.cisa.gov/phishing Official U.S. government guidance on phishing attack recognition, prevention strategies, and organisational best practices, including the recommendation to adopt phishing-resistant MFA solutions such as FIDO2 hardware security keys.

**[8] Europol — IOCTA (2021)**

InternetO rganisedCrimeThreat Assessment (IOCTA) 2021. Europol — European Union Agency for Law Enforcement Cooperation. Published: 2021. URL: https://www.europol.europa.eu/publications-events/main-reports/internet-organised-crime-threat-assessment-iocta-2021 Annual assessment of the cybercrime landscape across EU member states, confirming phishing as the primary initial attack vector for the majority of cybercrime incidents and data breaches investigated by European law enforcement.

**[9] Proofpoint (2023)**

Stateo f thePhish2023 — Annual Threat Intelligence Report. Proofpoint, Inc. Published: 2023. URL: https://www.proofpoint.com/us/resources/threat-reports/state-of-phish Proofpoint's annual global analysis of phishing threat trends, based on data from over 18 million simulated phishing emails and hundreds of thousands of real-world phishing reports. Provides statistics on attack frequency, industry targeting, and employee susceptibility rates.

**[10] Graham Ivan Clark — Sentencing (2021)**

Florida Teen GrahamC lark Sentenced inTwitter Hack Case. Tampa Bay Times / AP Wire. Published: March 17, 2021. URL: https://www.tampabay.com/news/crime/2021/03/17/florida-teen-gets-3-years-for-twitter-hack/ Reports on the sentencing hearing of Graham Ivan Clark, confirming the three-year juvenile detention sentence and subsequent probation terms, and providing context for the Florida juvenile sentencing framework that governed the case.

***Case Study prepared for Task 5 — Cybercrime Awareness Unit | Topic: Phishing | Incident: 2020 Twitter Bitcoin Scam | All sources are publicly available and verifiable.***